

7.15 D-I audit — one-array iteration

1. Identity and frozen scope

Sole audit agent: Codex. Worktree /private/tmp/kk715-di, branch release/715-stack-07b2b-erc7730-iteration. Owner authorized the two-part D split on 2026-09-27. Base is D-G firmware PR #868 at 93d8fb6c2827364172af6fd6719fe86606497839. Code snapshot 4449ac0f6be022238c8087ce08c80feec6c01cea. Python companion PR #118 pins dd7649b3a8d1ab43c2dbba8af5a9db1e1190769f. Other pins match D-G. Inherited CircleCI now clones the actual fork before testing. Canonical product release/7.15 is not updated. Historical PR #866 remains. This adjacent review contains iteration code, not a receipt-only change.

One calldata array at a time may be walked through tuples. Each formatter value and auxiliary path must belong to that array. Capture counts determine numbered screens; empty arrays advance without fabricated elements. Fixed and dynamic arrays share the same bounded workflow. Nested iteration is refused. Embedded calls remain outside this unit. D-G groups and optional visibility are retained.

2. Adjacent inventory

Frozen code range is 990e34c32..4449ac0f6; report predecessor is recorded in the final PR body. The regenerated table includes every adjacent path and final report source line count. Counts are net, not sums of overlapping commits.

Tracked path	Added	Deleted	Change and evidence
.github/workflows/ci.yml	1	1	Changed as part of this bounded audit unit.
deps/python-keepkey	1	1	Pins the matching compiler mirror and its tests.
docs/release/audit-units/715-07b2b-iteration-audit-20260927.md	121	0	Records exact scope, findings, inventory and validation.
docs/release/audit-units/715-07b2b-iteration-audit-20260927.pdf	-	-	Rendered audit evidence from the adjacent source report.
docs/security/HANDOFF-ERC7730-715-FORMATTERS.md	18	0	Records on-screen behavior and fail-closed limits.
include/keepkey/firmware/erc7730_capabilities.h	12	7	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_catalog.h	9	0	Declares bounded state and the phase's runtime contract.
include/keepkey/firmware/erc7730_workflow.h	13	0	Declares bounded state and the phase's runtime contract.
lib/firmware/erc7730_abi_stream.c	14	0	Captures only bounded ABI facts and records overflow.
lib/firmware/erc7730_capabilities.c	5	1	Selects the exact formatter and display capabilities.
lib/firmware/erc7730_catalog.c	69	9	Refuses unexecutable signed programs before review.
lib/firmware/erc7730_workflow.c	22	2	Keeps replay, validation and UI state in sequence.
lib/firmware/fsm_msg_ethereum.h	81	11	Shows and confirms the device-decoded review screens.
scripts/emulator/test_stack07_regressions.py	77	3	Exercises signed wire requests and review screens.
unittests/firmware/erc7730_catalog.cpp	193	66	Covers accepted neighbors and fail-closed boundaries.

ABI streaming captures counts only after validating the array structure. Catalog path classes bind full-array steps to one ABI array, and formatter flags reject scalar or other-array reuse. Workflow state preserves replay and screen index; failed capture initializes count before conditional reads. The wire test keeps dynamic, empty and address [2] exact screen controls. Production include/ and lib/ trees are byte-identical to repaired historical D 26ae09fe3; this child adds the retained D-G regressions and host-only fix.

3. Findings and class audit

- DI-01 fixed: the old compiler checked tuple member 2 (mixed arrays) instead of member 3 (signer constant) when refusing intent values. The regression demonstrably failed against old code and passes after the index correction. Firmware already refused this program. Inspected all formatter tuple reads: the remaining consumer destructures the four members consistently.
- D round 1 active-array auxiliary binding retained: every source-1 argument must use the value array. Same-array token address accepts; scalar or separate token paths refuse in native and host/device controls.
- D round 1 failed-capture count retained: initialize count to zero and read bytes only when capture, class and length all validate; malformed capture fails closed before iteration state advances.
- D round 2 count corrected: measured registry result is 1,273 of 1,450.
- D round 3 fixed-array coverage retained: both numbered address [2] element screens are required beside dynamic and empty-array cases.
- Original D10 parallel arrays, D11 iteration path limits, D14 numbered titles, D18 absent dynamic fixed index, and original Copilot scalar reuse all map to this child. D-G owns the original frame-storage defect; A–C and E retain their original finding ownership from the prior split receipt.
- Historical raw D13/D19 finding rows remain unavailable. That gap is not claimed closed by this audit. Physical-device checks remain pending.

Source audit traced array lengths, tuple reachability, path binding, formatter flags, initialized count, empty-array continuation, replay capture and numbered UI. Existing three-way array controls and the new constant boundary test cover host/device agreement. The retained D-G zero/nonzero optional fields are also exercised on the iteration candidate.

4. Verification

Same pinned Docker image as D-G, digest 7438e53933d47d53157ed6d96d864cb208597e62dce26235ace09d1063427fa2. Registry pin 9f37816afde954ff6617fb5baa346133e5af26c5.

Check	Result	Evidence/limits
Native firmware	653 passed	isolated clean run directory; di-native.xml
Compiler/validator	18 passed, zero skips	all 1,450 registry formats; 1,273 signable
Full Stack07 wire	39 passed	di-wire.xml; includes new D-G visibility regression
Constant-intent negative control	fails old code, passes repair	captured assertion showed host accepted what firmware refused
Production reconciliation	exact equality with repaired D	include/ and lib/ diff is empty against 26ae09fe3
Exact-head hosted gates	pending at report freeze	ARM, both variants, host, screenshots, report and evidence required before review
Physical device	not performed	release gate remains separate

An initial attempt ran native and wire processes in one emulator container; their shared UDP ports conflicted and invalidated that attempt. Those results are excluded. Qualifying native and wire runs execute sequentially.

5. Preflight and report

Final source/PDF inventory is checked against the adjacent Git diff; all PDF pages are visually inspected. Code-bearing gate must pass and empty-diff control fail. Canonical preflight retains only the prior owner-authorized inherited exceptions: duplicate nanobp options, missing report-gate test and cppcheck build-directory error. It is not reported as a passing local gate. Hosted static analysis and report/evidence gates must pass on the frozen head.

6. Retrospective and review

Zero new Copilot rounds at freeze, maximum three for this child. Preserve old PR #866 with its three used attempts. No review result is inherited. The new split caught a host mirror index regression missed by the older D review loop; explicit signer-constant acceptance/refusal neighbors now survive recombination. All prior D repairs remain. E-R follows on this exact base. No merge or release approval is claimed. Final head, companion PR and exact-head CI belong in the PR description without changing the frozen evidence snapshot.